



КОНЦЕПЦИЯ КИБЕРБЕЗОПАСНОСТИ

NIST Cybersecurity Framework (CSF) 2.0

(перевод для ознакомления)

Вячеслав Аксенов, IT Security Architect, vvaksionov@gmail.com

г. Минск, 2024



Введение

NIST Cybersecurity Framework (CSF) 2.0 содержит рекомендации для промышленности, государственных учреждений и других организаций по управлению рисками кибербезопасности. Он предлагает таксономию высокоуровневых результатов кибербезопасности, которые могут быть использованы любой организацией — независимо от ее размера, сектора или зрелости — для лучшего понимания, оценки, приоритизации и информирования о своих усилиях в области кибербезопасности. CSF не предписывает, каким образом должны быть достигнуты результаты. Скорее, он содержит ссылки на онлайн-ресурсы, которые содержат дополнительные рекомендации по методам и мерам контроля, которые могут быть использованы для достижения этих результатов. В этом документе описывается CSF 2.0, его компоненты и некоторые из многих способов его использования.

Ключевые слова

кибербезопасность; Концепция кибербезопасности (CSF); управление рисками кибербезопасности; управление рисками кибербезопасности; управление рисками предприятия; профили; уровни.

Целевая аудитория

Лица, ответственные за разработку и руководство программами кибербезопасности, являются основной аудиторией CSF. CSF также может использоваться другими лицами, участвующими в управлении рисками, включая руководителей, советы директоров, специалистов по закупкам, специалистов по технологиям, менеджеров по рискам, юристов, специалистов по кадрам, а также аудиторов по кибербезопасности и управлению рисками, для принятия решений, связанных с кибербезопасностью. Кроме того, CSF может быть полезен тем, кто разрабатывает политику и оказывает на нее влияние (например, ассоциациям, профессиональным организациям, регулирующим органам), кто устанавливает и доводит до сведения общественности приоритеты в области управления рисками кибербезопасности.

Дополнительный контент

NIST продолжит создавать и размещать дополнительные ресурсы, чтобы помочь организациям внедрить CSF, включая краткие руководства по началу работы и профили сообщества. Все ресурсы находятся в открытом доступе на сайте [Веб-сайт CSF NIST](#). Предложениями по дополнительным ресурсам для справки на веб-сайте NIST CSF всегда можно поделиться с NIST по адресу cyberframework@nist.gov.

Примечание для читателей

Если не указано иное, документы, упоминаемые или цитируемые в данной публикации, не полностью включены в эту публикацию.

До версии 2.0 Cybersecurity Framework назывался «Framework for Improving Critical Infrastructure Cybersecurity». Это название не используется для CSF 2.0.



NIST Cybersecurity Framework 2.0

Содержание

Введение	2
Ключевые слова.....	2
Целевая аудитория.....	2
Дополнительный контент	2
Примечание для читателей	2
Содержание	3
Предисловие.....	4
1. Обзор Концепции кибербезопасности (CSF).....	6
2. Введение в ядро CSF.....	8
3. Введение в профили и уровни CSF.....	11
3.1. Профили CSF	11
3.2. Уровни CSF	13
4. Знакомство с онлайн-ресурсами, дополняющими CSF.....	15
5. Улучшение коммуникации и интеграции рисков кибербезопасности.....	16
5.1. Совершенствование коммуникации в области управления рисками	16
5.2. Улучшение интеграции с другими программами управления рисками	18
Приложение А. Ядро CSF	21
Приложение Б. Уровни CSF.....	31
Приложение В. Глоссарий	34



NIST Cybersecurity Framework 2.0

Предисловие

Концепция кибербезопасности (CSF) 2.0 призвана помочь организациям всех размеров и секторов, включая промышленность, правительство, научные круги и некоммерческие организации, управлять рисками кибербезопасности и снижать их. Это полезно независимо от уровня зрелости и технической сложности программ кибербезопасности организации. Тем не менее, CSF не придерживается универсального подхода. Каждая организация имеет как общие, так и уникальные риски, а также различные склонности к риску и толерантности, конкретные миссии и цели для достижения этих целей. В силу необходимости способы внедрения CSF в организациях будут различаться.

В идеале CSF будет использоваться для устранения рисков кибербезопасности наряду с другими рисками предприятия, включая финансовые, конфиденциальные, репутационные, технологические или физические риски, риски конфиденциальности, цепочки поставок.

CSF *описывает* желаемые результаты, которые должны быть понятны широкой аудитории, включая руководителей, менеджеров и практикующих специалистов, независимо от их опыта в области кибербезопасности. Поскольку эти результаты нейтральны по отношению к сектору, стране и технологии, они обеспечивают организации гибкость, необходимую для учета уникальных рисков, технологий и миссии. Результаты сопоставляются непосредственно со списком потенциальных средств управления безопасностью для немедленного рассмотрения с целью снижения рисков кибербезопасности.

Несмотря на то, что CSF не носит предписывающего характера, он помогает своим пользователям в изучении и выборе конкретных результатов. Предложения о том, как можно достичь конкретных результатов, представлены в расширяющемся наборе онлайн-ресурсов, которые дополняют CSF, включая серию Руководств по быстрому старту (Quick Start Guides, QSGs). Кроме того, различные инструменты пред полагают возможность загрузки, чтобы помочь организациям, решившим автоматизировать некоторые из своих процессов. QSG предлагают первоначальные способы использования CSF и предлагают читателю более глубоко изучить CSF и связанные с ним ресурсы. Доступно через [Веб-сайт NIST CSF](#), CSF и эти дополнительные ресурсы от NIST и других организаций следует рассматривать как «портфель CSF», помогающий управлять рисками и снижать их. Независимо от того, как CSF применяется, он предлагает своим пользователям рассмотреть свою позицию в области кибербезопасности в контексте CSF, а затем адаптировать CSF к своим конкретным потребностям.

Основываясь на предыдущих версиях, CSF 2.0 содержит новые функции, которые подчеркивают важность *управления (governance)* и *цепочек поставок (supply chains)*. Особое внимание уделяется QSG для обеспечения актуальности CSF и легкодоступности как для небольших организаций, так и для их более крупных партнеров. NIST теперь предоставляет *примеры реализации (Implementation Examples)* и *информативные справочные материалы (Informative References)*, которые доступны в Интернете и регулярно обновляются. Создание текущего и целевого состояния профилей организации (*Organizational Profiles*) помогает организациям сравнивать, где они находятся с тем, где они хотят или должны быть, и позволяет им быстрее внедрять и оценивать элементы управления безопасностью.



NIST Cybersecurity Framework 2.0

Риски кибербезопасности постоянно растут, и управление этими рисками должно быть непрерывным процессом. Это верно независимо от того, только начинает ли организация сталкиваться с проблемами кибербезопасности или уже много лет работает со сложной, хорошо обеспеченной ресурсами командой по кибербезопасности. CSF разработан таким образом, чтобы быть ценным для организаций любого типа, и ожидается, что он будет обеспечивать надлежащее руководство в течение длительного времени.



1. Обзор Концепции кибербезопасности (CSF)

Этот документ представляет собой версию 2.0 NIST Cybersecurity Framework (CSF). Он включает в себя следующие компоненты:

- **CSF Core**, ядро CSF, которое представляет собой таксономию высокоуровневых результатов кибербезопасности, которые могут помочь любой организации управлять рисками кибербезопасности. Основные компоненты CSF представляют собой иерархию функций, категорий и подкатегорий, в которых подробно описывается каждый результат. Эти результаты могут быть понятны широкой аудитории, включая руководителей, менеджеров и практикующих специалистов, независимо от их опыта в области кибербезопасности. Поскольку результаты не зависят от сектора, страны и технологии, они обеспечивают организации гибкость, необходимую для учета уникальных рисков, технологий и миссии.
- **Организационные профили (Organizational Profiles) CSF**, которые представляют собой механизм для описания текущего и/или целевого состояния кибербезопасности организации с точки зрения результатов ядра CSF.
- **Уровни (Tiers) CSF**, которые могут быть применены к организационным профилям CSF для характеристики строгости методов управления рисками кибербезопасности и управления рисками кибербезопасности в организации. Уровни также могут предоставить контекст для того, как организация рассматривает риски кибербезопасности и используемые процессы для управления этими рисками.

В этом документе описывается, к каким желаемым результатам может стремиться организация. В нем не *предписываются* ни результаты, ни то, как они могут быть достигнуты. Описания того, как организация может достичь этих результатов, представлены в наборе онлайн-ресурсов, которые дополняют CSF и доступны на [веб-сайте NIST CSF](#). Эти ресурсы предлагают дополнительные рекомендации по методам и средствам контроля, которые могут быть использованы для достижения результатов и предназначены для того, чтобы помочь организации понять, принять и использовать CSF. К ним относятся:

- [Информативные ссылки \(Informative References\)](#) , указывающие на источники рекомендаций по каждому результату из существующих глобальных стандартов, руководящих принципов, структур, правил, политик и т.д.
- [Примеры реализации \(Implementation Examples\)](#) , иллюстрирующие потенциальные способы достижения каждого результата
- [Краткие руководства \(Quick-Start Guides\)](#) , содержащие практические рекомендации по использованию CSF и его онлайн-ресурсов, включая переход с предыдущих версий CSF на версию 2.0
- [Профили сообщества \(Community Profiles\) и шаблоны профилей организации \(Organizational Profile Templates\)](#) , которые помогают организации применять CSF на практике и устанавливать приоритеты для управления рисками кибербезопасности

Организация может использовать ядро (Core), профили (Profiles) и уровни (Tiers) CSF с дополнительными ресурсами для понимания, оценки, приоритизации и информирования о рисках кибербезопасности.



NIST Cybersecurity Framework 2.0

- **Понимание и оценка:** Опишите текущее или целевое состояние кибербезопасности части или всей организации, определите пробелы и оцените прогресс в устранении этих пробелов.
- **Приоритизация:** Выявление, организация и приоритизация действий по управлению рисками кибербезопасности, которые соответствуют миссии организации, законодательным и нормативным требованиям, а также ожиданиям в области управления рисками и управления.
- **Общение:** Обеспечьте общий язык для общения внутри и за пределами организации о рисках, возможностях, потребностях и ожиданиях кибербезопасности.

CSF предназначен для использования организациями всех размеров и секторов, включая промышленность, правительство, научные круги и некоммерческие организации, независимо от уровня зрелости их программ кибербезопасности. CSF является основополагающим ресурсом, который может быть принят на добровольной основе и в рамках государственной политики и мандатов. Таксономия CSF и соответствующие стандарты, руководящие принципы и практики не являются специфическими для конкретной страны, и предыдущие версии CSF были успешно использованы многими правительствами и другими организациями как в Соединенных Штатах, так и за их пределами.

CSF следует использовать в сочетании с другими ресурсами (например, структурами, стандартами, руководящими принципами, передовым опытом) для более эффективного управления рисками кибербезопасности и информирования об общем управлении рисками в области информационно-коммуникационных технологий (ИКТ) на уровне предприятия. CSF — это гибкая структура, предназначенная для использования всеми организациями, независимо от их размера. Организации по-прежнему будут обладать уникальными рисками, включая различные угрозы и уязвимости, и толерантными рисками, а также уникальными целями и требованиями миссии. Таким образом, подходы организаций к управлению рисками и их реализации CSF будут различаться.

Остальная часть этого документа структурирована следующим образом:

- Раздел 2 объясняет основы ядра CSF: функции (Functions), категории (Categories) и подкатегории (Subcategories).
- Раздел 3 определяет понятия профилей (Profiles) и уровней (Tiers) CSF.
- В разделе 4 представлен обзор отдельных компонентов набора онлайн-ресурсов CSF: Информативные ссылки (Informative References), Примеры реализации (Implementation Examples) и Краткие руководства (Quick Start Guides).
- В разделе 5 обсуждается, как организация может интегрировать CSF с другими программами управления рисками.
- Приложение А представляет собой ядро CSF.
- Приложение В содержит условную иллюстрацию уровней CSF.
- Приложение С представляет собой глоссарий терминологии CSF.

2. Введение в ядро CSF

Приложение А — это ядро CSF — набор результатов кибербезопасности, упорядоченных по функциям, категориям и, наконец, подкатегориям, как показано на рисунке 1. Эти результаты не являются контрольным списком действий, которые необходимо выполнить; Конкретные действия, предпринимаемые для достижения результата, зависят от организации и случая использования. Кроме того, порядок и размер функций, категорий и подкатегорий в ядре не подразумевают последовательность или важность их достижения. Структура Ядра призвана наилучшим образом резонировать с теми, кто отвечает за внедрение управления рисками в организации.

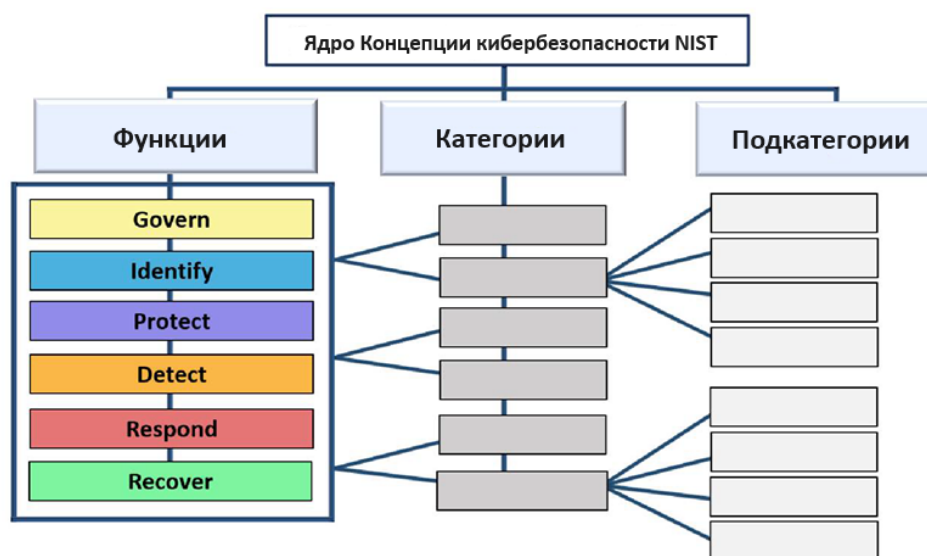


Рис 1. Структура ядра CSF

Основные функции CSF — GOVERN (Управлять), IDENTIFY (Идентифицировать), PROTECT (Защищать), DETECT (Обнаруживать), RESPOND (Реагировать), и RECOVER (Восстанавливать) — организуют результаты кибербезопасности на самом высоком уровне.

- **GOVERN (GV), Управлять** — *Стратегия, ожидания и политика организации по управлению рисками кибербезопасности, которые разрабатываются, доводятся до сведения и контролируются.* Функция GOVERN предоставляет результаты, чтобы информировать о том, что организация может сделать для достижения, и расставлять приоритеты результатов других пяти функций в контексте ее миссии и ожиданий заинтересованных сторон. Деятельность по управлению имеет решающее значение для включения кибербезопасности в более широкую стратегию управления рисками предприятия (enterprise risk management, ERM) организации. GOVERN направлен на понимание организационного контекста; разработка стратегии кибербезопасности и управление рисками в цепочке поставок кибербезопасности; роли, обязанности и полномочия; политика; и надзор за стратегией кибербезопасности.
- **IDENTIFY (ID), Идентифицировать** — *Понимание текущих рисков кибербезопасности организации.* Понимание активов организации (например, данных, оборудования, программного обеспечения, систем, объектов, услуг, людей), поставщиков и связанных с ними рисков кибербезопасности позволяет организации расставлять приоритеты в своих усилиях в соответствии со стратегией управления рисками и потребностями миссии, определенными в рамках GOVERN. Эта функция также включает в себя выявление



NIST Cybersecurity Framework 2.0

возможностей для улучшения политик, планов, процессов, процедур и практики организации, поддерживающих управление рисками кибербезопасности, для информирования усилий в рамках всех шести функций.

- **PROTECT (PR), Защищать** — *Используются меры безопасности для управления рисками кибербезопасности организации.* После того как активы и риски определены и приоритизированы, PROTECT поддерживает способность защищать эти активы для предотвращения или снижения вероятности и воздействия неблагоприятных событий в области кибербезопасности, а также для повышения вероятности и влияния использования возможностей. К результатам, охватываемым этой функцией, относятся управление идентификацией, аутентификация и контроль доступа; повышение осведомленности и профессиональная подготовка; безопасность данных; безопасность платформы (т. е. обеспечение безопасности оборудования, программного обеспечения и услуг, физических и виртуальных платформ); и устойчивость технологической инфраструктуры.
- **DETECT (DE), Обнаруживать** — *Возможные атаки и компрометации кибербезопасности обнаруживаются и анализируются.* DETECT позволяет своевременно обнаруживать и анализировать аномалии, индикаторы компрометации и другие потенциально неблагоприятные события, которые могут указывать на то, что происходят атаки и инциденты кибербезопасности. Эта функция поддерживает успешное реагирование на инциденты и восстановление после них.
- **RESPONSE (RS), Реагировать** — *Предпринимаются действия в отношении обнаруженного инцидента кибербезопасности.* RESPOND поддерживает возможность сдерживания последствий инцидентов кибербезопасности. Результаты в рамках этой функции охватывают управление инцидентами, анализ, снижение последствий, отчетность и коммуникацию.
- **RECOVER (RC), Восстанавливать** — *Активы и операции, пострадавшие от инцидента кибербезопасности, восстанавливаются.* RECOVER поддерживает своевременное восстановление нормальной работы, чтобы уменьшить последствия инцидентов кибербезопасности и обеспечить надлежащую связь во время восстановительных работ.

Несмотря на то, что многие мероприятия по управлению рисками кибербезопасности направлены на предотвращение негативных событий, они также могут способствовать использованию положительных возможностей. Действия по снижению рисков кибербезопасности могут принести пользу организации и в других отношениях, таких как увеличение доходов (например, сначала предоставление избыточного пространства коммерческому хостинг-провайдеру для размещения собственных и чужих дата-центров, а затем перенос крупной финансовой системы из собственного дата-центра организации к хостинг-провайдеру для снижения рисков кибербезопасности).

На рисунке 2 функции CSF показаны в виде колеса, поскольку все функции связаны друг с другом. Например, организация классифицирует активы в соответствии с IDENTIFY и предпринимает шаги для обеспечения безопасности этих активов в соответствии с PROTECT. Инвестиции в планирование и тестирование в функциях GOVERN и IDENTIFY будут способствовать своевременному обнаружению непредвиденных событий в функции DETECT, а также позволят реагировать на инциденты и восстанавливаться после инцидентов кибербезопасности в функциях RESPONSE и RECOVER. GOVERN находится в центре колеса, потому что он информирует о том, как организация будет реализовывать остальные пять функций.

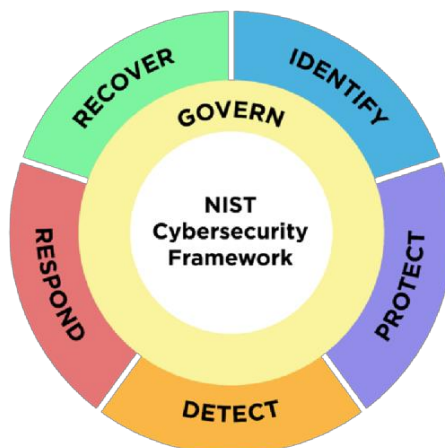


Рис 2. Функции CSF

Функции должны рассматриваться параллельно. Действия, поддерживающие GOVERN, IDENTIFY, PROTECT, и DETECT, должны выполняться непрерывно, а действия, поддерживающие RESPONSE и RECOVER, должны быть готовы в любое время и возникать при возникновении инцидентов кибербезопасности. Все функции играют жизненно важную роль, связанную с инцидентами кибербезопасности. Результаты GOVERN, IDENTIFY и PROTECT помогают предотвращать инциденты и готовиться к ним, в то время как результаты GOVERN, DETECT, RESPOND и RECOVER помогают обнаруживать инциденты и управлять ими.

Каждая функция названа в честь глагола, который обобщает ее содержимое. Каждая Функция разделена на *Категории*, которые представляют собой связанные результаты кибербезопасности, которые в совокупности составляют Функцию. *Подкатегории* далее делят каждую категорию на более конкретные результаты технической и управленческой деятельности. Подкатегории не являются исчерпывающими, но они подробно описывают результаты, которые поддерживают каждую категорию.

Функции, категории и подкатегории применяются ко всем ИКТ, используемым организацией, включая информационные технологии (ИТ), Интернет вещей (Internet of Things, IoT) и операционные технологии (operational technology, OT). Они также применимы ко всем типам технологических сред, включая облачные, мобильные и системы искусственного интеллекта. Ядро CSF ориентировано на будущее и предназначено для применения к будущим изменениям в технологиях и средах.



3. Введение в профили и уровни CSF

В этом разделе определяются понятия профилей и уровней CSF.

3.1. Профили CSF

Организационный профиль CSF описывает текущее и/или целевое состояние кибербезопасности организации с точки зрения результатов Ядра. [Организационные профили](#) используются для понимания, адаптации, оценки, приоритизации и информирования о результатах работы Ядра с учетом целей миссии организации, ожиданий заинтересованных сторон, ландшафта угроз и требований. Затем организация может расставить приоритеты в своих действиях для достижения конкретных результатов и донести эту информацию до заинтересованных сторон.

Каждый организационный профиль включает в себя один или оба из следующих элементов:

- А. *Текущий профиль (Current Profile)* определяет основные результаты, которые организация в настоящее время достигает (или пытается достичь), а также характеризует, как или в какой степени достигается каждый результат.
- Б. *Целевой профиль (Target Profile)* определяет желаемые результаты, которые организация выбрала и приоритизировала для достижения своих целей в области управления рисками кибербезопасности. Целевой профиль учитывает ожидаемые изменения в состоянии кибербезопасности организации, такие как новые требования, внедрение новых технологий и тенденции в области анализа угроз.

Профиль *сообщества* — это базовый уровень результатов CSF, который создается и публикуется с учетом общих интересов и целей ряда организаций. Профиль сообщества обычно разрабатывается для определенного сектора, подсектора, технологии, типа угрозы или другого варианта использования. Организация может использовать профиль сообщества в качестве основы для своего собственного целевого профиля. Примеры профилей сообщества можно найти на [веб-сайте NIST CSF](#).

Шаги, показанные на рисунке 3 и кратко изложенные ниже, иллюстрируют один из способов, с помощью которого организация может использовать организационный профиль для непрерывного улучшения своей кибербезопасности.



Рис 3. Шаги по созданию и использованию организационного профиля CSF

- А. **Область действия организационного профиля.** Задокументируйте высокоуровневые факты и предположения, на которых будет основан профиль, чтобы определить его область. Организация может иметь любое количество организационных профилей, каждый из которых имеет свою область. Например, профиль может быть адресован всей организации или ограничен финансовыми системами организации или противодействием угрозам программ-вымогателей и обработкой инцидентов с программами-вымогателями, связанными с этими финансовыми системами.
- Б. **Соберите информацию, необходимую для подготовки организационного профиля.** Примеры информации могут включать организационные политики, приоритеты и ресурсы управления рисками, профили рисков предприятия, результаты анализа воздействия на бизнес (BIA), требования и стандарты кибербезопасности, которым следует организация, методы и инструменты (например, процедуры и меры безопасности), а также рабочие роли.
- В. **Создайте профиль организации.** Определите, какие типы информации должен включать профиль для выбранных результатов CSF, и задокументируйте необходимую информацию. Учитывайте риски текущего профиля для обоснования планирования и определения приоритетов целевого профиля. Кроме того, рассмотрите возможность использования профиля сообщества в качестве основы для целевого профиля.
- Г. **Проанализируйте расхождения между текущим и целевым профилями и составьте план действий.** Проведите анализ пробелов для выявления и анализа различий между текущим и целевым профилями, а также разработайте план действий с указанием приоритетов (например, реестр рисков, подробный отчет о рисках, план действий и контрольные точки [Plan of Action and Milestones, POA&M]) для устранения этих пробелов.
- Д. **Реализуйте план действий и обновите организационный профиль.** Следуйте плану действий для устранения пробелов и продвижения организации к целевому профилю. План действий может иметь общий срок или быть постоянным.

Учитывая важность постоянного совершенствования, организация может повторять эти шаги так часто, как это необходимо.

NIST Cybersecurity Framework 2.0

Существуют дополнительные возможности использования организационных профилей. Например, текущий профиль можно использовать для документирования и информирования внешних заинтересованных сторон, таких как деловые партнеры или потенциальные клиенты, о возможностях организации в области кибербезопасности и известных возможностях для улучшения. Кроме того, целевой профиль может помочь выразить требования и ожидания организации в области управления рисками кибербезопасности поставщикам, партнерам и другим третьим сторонам в качестве цели, которую эти стороны должны достичь.

3.2. Уровни CSF

Организация может использовать уровни для информирования своих текущих и целевых профилей. Уровни характеризуют строгость методов управления рисками кибербезопасности и управления рисками кибербезопасности в организации, а также обеспечивают контекст того, как организация рассматривает риски кибербезопасности и используемые процессы управления этими рисками. Уровни, как показано на рисунке 4 и условно проиллюстрированы в Приложении В, отражают практику организации по управлению рисками кибербезопасности: Частичный (Partial) (уровень 1), Информированный о рисках (Risk Informed) (уровень 2), Повторяемый (Repeatable) (уровень 3) и Адаптивный (Adaptive) (уровень 4). Уровни описывают переход от неформальных, разовых ответов к гибким, основанным на учете рисков и постоянно совершенствующимся подходам. Выбор уровней помогает задать общий тон тому, как организация будет управлять рисками кибербезопасности.



Рис 4. Уровни CSF для управления и управления рисками кибербезопасности

Уровни должны дополнять методологию управления рисками кибербезопасности организации, а не заменять ее. Например, организация может использовать уровни для внутренней коммуникации в качестве эталона для общеорганизационного¹ подхода к управлению рисками кибербезопасности. Переход на более высокие уровни поощряется в тех случаях, когда риски или мандаты являются более значительными или когда анализ затрат и выгод указывает на осуществимое и экономически эффективное снижение негативных рисков кибербезопасности.

¹ Для целей настоящего документа термины «общеорганизационный» (organization-wide) и «корпоративный» (enterprise) имеют одно и то же значение.



NIST Cybersecurity Framework 2.0

На [веб-сайте NIST CSF](#) представлена дополнительная информация об использовании профилей и уровней. Он включает в себя указатели на [шаблоны профилей организаций, размещенные в NIST](#), и репозиторий [профилей сообщества](#) в различных форматах.



4. Знакомство с онлайн-ресурсами, дополняющими CSF

NIST и другие организации создали набор онлайн-ресурсов, которые помогают организациям понять, внедрить и использовать CSF. Поскольку они размещены в Интернете, эти дополнительные ресурсы могут обновляться чаще, чем этот документ, который обновляется нечасто, чтобы обеспечить стабильность для пользователей, и быть доступными в машиночитаемых форматах. В этом разделе представлен обзор трех типов онлайн-ресурсов: Информативные ссылки (Informative References), Примеры реализации (Implementation Examples) и Руководства по быстрому запуску (Quick Start Guides).

[Информативные ссылки](#) — это сопоставления, которые указывают на отношения между Ядром и различными стандартами, руководствами, правилами и другим контентом. Информативные ссылки помогают понять, как организация может достичь результатов Ядра. Информативные ссылки могут быть отраслевыми или технологическими. Они могут быть подготовлены NIST или другой организацией. Некоторые информативные ссылки имеют более узкую область, чем подкатегория. Например, конкретный элемент управления из [SP 800-53](#) «*Security and Privacy Controls for Information Systems and Organizations*» может быть одной из многих ссылок, необходимых для достижения результата, описанного в одной подкатегории. Другие информативные ссылки могут быть более высокого уровня, например, требование политики, которое частично затрагивает многочисленные подкатегории. При использовании CSF организация может определить наиболее релевантные информационные ссылки.

[Примеры реализации](#) представляют собой условные примеры кратких, ориентированных на действия шагов, помогающих достичь результатов подкатегорий. Глаголы, используемые для выражения Примеры: делиться, документировать, разрабатывать, выполнять, контролировать, анализировать, оценивать и упражняться. Примеры не являются исчерпывающим перечнем всех действий, которые могут быть предприняты организацией для достижения результата, а также не представляют собой базовый уровень необходимых действий для устранения рисков кибербезопасности.

[Руководства по быстрому запуску \(QSG\)](#) представляют собой краткие документы по конкретным темам, связанным с CSF, и часто адаптированы к конкретным аудиториям. QSG могут помочь организации внедрить CSF, потому что они превращают конкретные части CSF в действенные «первые шаги», которые организация может рассмотреть на пути к улучшению своей кибербезопасности и управлению связанными рисками. Руководства пересматриваются в соответствующих временных рамках, а новые руководства добавляются по мере необходимости.

Предложения по новым информативным справочным материалам для CSF 2.0 всегда можно отправить в NIST по адресу olir@nist.gov. Предложения по другим ресурсам для ссылок на веб-сайте NIST CSF, включая дополнительные темы QSG, следует направлять по адресу cyberframework@nist.gov.



5. Улучшение коммуникации и интеграции рисков кибербезопасности

Использование CSF будет варьироваться в зависимости от уникальной миссии организации и рисков. Понимая ожидания заинтересованных сторон, а также склонность к риску и толерантность (как указано в GOVERN), организация может расставлять приоритеты в действиях по обеспечению кибербезопасности, чтобы принимать обоснованные решения о расходах и действиях в области кибербезопасности. Организация может выбрать управление рисками одним или несколькими способами, включая смягчение, передачу, предотвращение или принятие негативных рисков, а также реализацию, совместное использование, усиление или принятие положительных рисков, в зависимости от потенциальных последствий и вероятностей. Важно отметить, что организация может использовать CSF как внутри организации для управления своими возможностями в области кибербезопасности, так и за ее пределами для надзора или общения с третьими сторонами.

Независимо от того, как используется CSF, организация может извлечь выгоду из использования CSF в качестве руководства, которое поможет ей понять, оценить, приоритизировать и сообщить о рисках кибербезопасности и действиях, которые позволят управлять этими рисками. Выбранные результаты могут быть использованы для сосредоточения внимания и реализации стратегических решений по улучшению состояния кибербезопасности и поддержанию преемственности основных функций миссии с учетом приоритетов и имеющихся ресурсов.

5.1. Совершенствование коммуникации в области управления рисками

CSF обеспечивает основу для улучшения коммуникации в отношении ожиданий, планирования и ресурсов в области кибербезопасности. CSF способствует двустороннему информационному потоку (как показано в верхней половине рисунка 5) между руководителями, которые сосредоточены на приоритетах организации и стратегическом направлении, и менеджерами, которые управляют конкретными рисками кибербезопасности, которые могут повлиять на достижение этих приоритетов. CSF также поддерживает аналогичный поток (как показано в нижней половине рисунка 5) между менеджерами и практиками, которые внедряют и эксплуатируют технологии. Левая часть рисунка указывает на важность того, чтобы практикующие специалисты делились своими новостями, идеями и проблемами с менеджерами и руководителями.



Рис.5. Использование CSF для улучшения коммуникации в области управления рисками

Подготовка к созданию и использованию профилей организации включает в себя сбор информации о приоритетах организации, ресурсах и управлении рисками от руководителей. Затем менеджеры сотрудничают с практиками для информирования о потребностях бизнеса и создания организационных профилей с учетом рисков. Меры по устранению любых расхождений, выявленных между текущим и целевым профилями, будут реализованы руководителями и специалистами-практиками и обеспечат ключевые входные данные в планы на системном уровне. По мере того, как целевое состояние достигается во всей организации, в том числе с помощью средств контроля и мониторинга, применяемых на системном уровне, обновленные результаты могут быть переданы в реестры рисков и отчеты о ходе работы. В рамках текущей оценки менеджеры получают информацию для внесения корректив, которые еще больше снижают потенциальный вред и увеличивают потенциальную пользу.

Функция GOVERN поддерживает коммуникацию между **руководителями** по организационным рискам. Обсуждения руководителей включают в себя стратегию, в частности, то, как неопределенности, связанные с кибербезопасностью, могут повлиять на достижение целей организации. Эти обсуждения в области управления способствуют диалогу и соглашению о стратегиях управления рисками (включая риски в цепочке поставок кибербезопасности); роли, обязанности и полномочия; голитики; и надзор. Когда руководители устанавливают приоритеты и цели в области кибербезопасности на основе этих потребностей, они сообщают об ожиданиях в отношении склонности к риску, подотчетности и ресурсов. Руководители также несут ответственность за интеграцию управления рисками кибербезопасности с программами корпоративного управления риском (ERM) и программами управления рисками более низкого уровня (см. раздел 5.2). Коммуникации, отраженные в верхней половине рисунка 5, могут включать в себя соображения по ERM и программам более низкого уровня и, таким образом, информировать менеджеров и специалистов.

Общие цели кибербезопасности, поставленные руководителями, основаны на информации **менеджеров** и распространяются на **них**. В коммерческой организации они могут применяться к



NIST Cybersecurity Framework 2.0

направлению деятельности или операционному подразделению. Для государственных учреждений это могут быть соображения на уровне подразделений или филиалов. При внедрении CSF менеджеры сосредоточатся на том, как достичь целевых показателей рисков с помощью общих услуг, средств контроля и сотрудничества, как это отражено в профиле цели и улучшено с помощью действий, отслеживаемых в плане действий (например, реестр рисков, подробный отчет о рисках, POA&M).

Специалисты сосредотачиваются на реализации целевого состояния и измерении изменений в операционных рисках, чтобы помочь планировать, выполнять и контролировать конкретные действия в области кибербезопасности. По мере того, как средства контроля внедряются для управления рисками на приемлемом уровне, практикующие специалисты предоставляют менеджерам и руководителям информацию (например, ключевые показатели эффективности, ключевые индикаторы риска), необходимую им для понимания состояния кибербезопасности организации, принятия обоснованных решений и поддержания или корректировки стратегии управления рисками в соответствии с ней. Руководители также могут объединять эти данные о рисках кибербезопасности с информацией о других типах рисков в масштабах всей организации. Обновления ожиданий и приоритетов включаются в обновленные организационные профили по мере повторения цикла.

5.2. Улучшение интеграции с другими программами управления рисками

Каждая организация сталкивается с многочисленными типами рисков ИКТ (например, конфиденциальность, цепочка поставок, искусственный интеллект) и может использовать структуры и инструменты управления, специфичные для каждого риска. Некоторые организации интегрируют ИКТ и все другие усилия по управлению рисками на высоком уровне за счет использования ERM, в то время как другие прилагают усилия отдельно, чтобы обеспечить должное внимание к каждому. Небольшие организации по своей природе могут отслеживать риски на уровне предприятия, в то время как более крупные компании могут проводить отдельные мероприятия по управлению рисками, интегрированные в ERM.

Организации могут использовать подход ERM для балансировки *портфеля* рисков, включая кибербезопасность, и принятия обоснованных решений. Руководители получают значительную информацию о текущей и планируемой деятельности по управлению рисками, поскольку они интегрируют стратегии управления и управления рисками с результатами предыдущего использования CSF. CSF помогает организациям перевести свою терминологию для кибербезопасности и управления рисками кибербезопасности на общий язык управления рисками, понятный руководителям.

Ресурсы NIST, описывающие взаимосвязь между управлением рисками кибербезопасности и ERM, включают:

- NIST Cybersecurity Framework 2.0 – [Enterprise Risk Management Quick-Start Guide](#)
- NIST Interagency Report (IR) 8286, [Integrating Cybersecurity and Enterprise Risk Management \(ERM\)](#)
- IR 8286A, [Identifying and Estimating Cybersecurity Risk for Enterprise Risk Management](#)
- IR 8286B, [Prioritizing Cybersecurity Risk for Enterprise Risk Management](#)

NIST Cybersecurity Framework 2.0

- IR 8286C, [Staging Cybersecurity Risks for Enterprise Risk Management and Governance Oversight](#)
- IR 8286D, [Using Business Impact Analysis to Inform Risk Prioritization and Response](#)
- SP 800-221, [Enterprise Impact of Information and Communications Technology Risk: Governing and Managing ICT Risk Programs Within an Enterprise Risk Portfolio](#)
- SP 800-221A, [Information and Communications Technology \(ICT\) Risk Outcomes: Integrating ICT Risk Management Programs with the Enterprise Risk Portfolio](#)

Организация также может считать CSF полезной для интеграции управления рисками кибербезопасности с отдельными программами управления рисками ИКТ, такими как:

- **Управление рисками кибербезопасности и их оценка:** CSF может быть интегрирован с установленными программами управления рисками и оценки рисков кибербезопасности, такими как [SP 800-37, Risk Management Framework for Information Systems and Organizations](#), and [SP 800-30, Guide for Conducting Risk Assessments](#) в соответствии с NIST Risk Management Framework (RMF). Для организаций, использующих [NIST RMF и его набор публикаций](#), CSF может быть использован в качестве дополнения подхода RMF к выбору и приоритизации элементов управления из [SP 800-53, Security and Privacy Controls for Information Systems and Organizations](#).
- **Риски приватности:** Хотя кибербезопасность и приватность являются независимыми дисциплинами, их цели в определенных обстоятельствах пересекаются, как показано на рисунке 6.



Рис 6. Взаимосвязь между рисками кибербезопасности и приватности

Управление рисками кибербезопасности имеет важное значение для устранения рисков приватности, связанных с потерей конфиденциальности, целостности и доступности данных физических лиц. Например, утечка данных может привести к краже личных данных. Однако риски конфиденциальности также могут возникать из-за средств, не связанных с инцидентами кибербезопасности.

Организация обрабатывает данные для выполнения миссии или достижения деловых целей, что иногда может привести к *событиям приватности*, в результате которых



NIST Cybersecurity Framework 2.0

отдельные лица могут столкнуться с проблемами в результате обработки данных. Эти проблемы могут выражаться по-разному, но NIST описывает их как влияние на достоинства (например, смущение или позор) до более ощутимого вреда (например, дискриминация, экономические потери или физический вред). [NIST Privacy Framework](#) и [Cybersecurity Framework](#) могут использоваться вместе для решения различных аспектов кибербезопасности и рисков конфиденциальности. Кроме того, [методология оценки рисков конфиденциальности приватности \(Privacy Risk Assessment Methodology, PRAM\)](#) NIST содержит каталог примеров проблем для использования при оценке рисков конфиденциальности.

- **Риски в цепочке поставок:** организация может использовать CSF для улучшения надзора за рисками кибербезопасности и коммуникации с заинтересованными сторонами в цепочках поставок. Все типы технологий опираются на сложную, глобально распределенную, обширную и взаимосвязанную экосистему цепочек поставок с географически разнообразными маршрутами и несколькими уровнями аутсорсинга. Эта экосистема состоит из организаций государственного и частного секторов (например, покупателей, поставщиков, разработчиков, системных интеграторов, внешних поставщиков системных услуг и других поставщиков услуг, связанных с технологиями), которые взаимодействуют в целях исследования, разработки, проектирования, производства, приобретения, поставки, интеграции, эксплуатации, обслуживания, утилизации и иного использования или управления технологическими продуктами и услугами. Эти взаимодействия формируются и зависят от технологий, законов, политик, процедур и практик.

Учитывая сложные и взаимосвязанные отношения в этой экосистеме, управление рисками в цепочке поставок (supply chain risk management, SCRM) имеет решающее значение для организаций. Cybersecurity SCRM (C-SCRM) — это систематический процесс управления рисками кибербезопасности во всех цепочках поставок и разработки соответствующих стратегий, политик, процессов и процедур реагирования. Подкатегории в рамках CSF C-SCRM Category [GV. SC] обеспечивают связь между результатами, которые сосредоточены исключительно на кибербезопасности, и теми, которые сосредоточены на C-SCRM. SP 800-161r1 (Revision 1), [Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations](#) содержит подробную информацию о C-SCRM.

- **Риски, связанные с новыми технологиями:** По мере того, как становятся доступными новые технологии и новые приложения технологий, становятся очевидными новые риски. Современным примером является искусственный интеллект (ИИ), который несет в себе риски кибербезопасности и приватности, а также многие другие виды рисков. Для устранения этих рисков была разработана система управления рисками искусственного интеллекта [NIST Artificial Intelligence Risk Management Framework \(AI RMF\)](#). Рассмотрение рисков, связанных с ИИ, наряду с другими корпоративными рисками (например, финансовыми, кибербезопасности, репутационными и приватности) приведет к более интегрированным результатам и организационной эффективности. Соображения и подходы к управлению рисками кибербезопасности и приватности применимы к проектированию, разработке, развертыванию, оценке и использованию систем ИИ. Ядро AI RMF использует функции, категории и подкатегории для описания результатов ИИ и помощи в управлении рисками, связанными с ИИ.



Приложение А. Ядро CSF

В этом приложении описываются функции, категории и подкатегории ядра CSF. В таблице 1 перечислены названия основных функций и категорий CSF 2.0, а также уникальные буквенные идентификаторы. Имя каждой функции в таблице связано с соответствующей частью приложения. Порядок функций, категорий и подкатегорий Ядра не является алфавитным; Он призван найти наибольший отклик у тех, кто отвечает за внедрение управления рисками в организации. Нумерация подкатегорий намеренно не является последовательной; пробелы в нумерации указывают на подкатегории CSF 1.1, которые были перемещены в CSF 2.0.

Таблица 1. CSF 2.0 Основные функции и названия и идентификаторы категорий

Функция	Категория	Идентификатор категории
<u>GOVERN (GV)</u> Управлять	Organizational Context (Организационный контекст)	GV.OC
	Risk Management Strategy (Стратегия управления рисками)	GV.RM
	Roles, Responsibilities, and Authorities (Роли, обязанности и полномочия)	GV.RR
	Policy (Политика)	GV.PO
	Oversight (Надзор)	GV.OV
	Cybersecurity Supply Chain Risk Management (Управление рисками кибербезопасности в цепочке поставок)	GV.SC
<u>IDENTIFY (ID)</u> Идентифицировать	Asset Management (Управление активами)	ID.AM
	Risk Assessment (Оценка риска)	ID.RA
	Improvement (Улучшение)	ID.IM
<u>PROTECT (PR)</u> Защищать	Identity Management, Authentication, and Access Control (Управление идентификацией, аутентификация и контроль доступа)	PR.AA
	Awareness and Training (Повышение осведомленности и обучение)	PR.AT
	Data Security (Безопасность данных)	PR.DS
	Platform Security (Безопасность платформы)	PR.PS
	Technology Infrastructure Resilience (Устойчивость технологической инфраструктуры)	PR.IR
<u>DETECT (DE)</u> Обнаруживать	Continuous Monitoring (Непрерывный мониторинг)	DE.CM
	Adverse Event Analysis (Анализ нежелательных событий)	DE.AE
<u>RESPOND (RS)</u> Реагировать	Incident Management (Управление инцидентами)	RS.MA
	Incident Analysis (Анализ инцидентов)	RS.AN
	Incident Response Reporting and Communication (Отчетность и коммуникация по реагированию на инциденты)	RS.CO
	Incident Mitigation (Устранение последствий инцидентов)	RS.MI



NIST Cybersecurity Framework 2.0

Функция	Категория	Идентификатор категории
RECOVER (RC) Восстанавливать	Incident Recovery Plan Execution (Выполнение плана восстановления после инцидентов)	RC.RP
	Incident Recovery Communication (Коммуникация по восстановлению после инцидентов)	RC.CO

Ядро CSF, информативные справочники и примеры реализации доступны на веб-сайте [CSF 2.0](#) и через [CSF 2.0 Reference Tool](#), который позволяет пользователям изучать их и экспортировать в человеко- и машиночитаемые форматы. Ядро CSF 2.0 также доступно в [устаревшем формате](#), аналогичном CSF 1.1.

GOVERN (GV): Стратегия, ожидания и политика организации по управлению рисками кибербезопасности устанавливаются, доводятся до сведения и контролируются

- **Организационный контекст (GV.OC):** Обстоятельства — миссия, ожидания заинтересованных сторон, зависимости, а также юридические, нормативные и договорные требования — связанные с решениями организации по управлению рисками кибербезопасности, понимаются
 - **GV. OC-01:** Миссия организации понимается и информирует управление рисками кибербезопасности
 - **GV. OC-02:** Внутренние и внешние заинтересованные стороны, а также их потребности и ожидания в отношении управления рисками кибербезопасности понимаются и учитываются
 - **GV. OC-03:** Правовые, нормативные и договорные требования в отношении кибербезопасности, включая обязательства по обеспечению приватности и гражданским свободам, поняты и управляются
 - **GV. OC-04:** Критически важные цели, возможности и услуги, от которых внешние заинтересованные стороны зависят или ожидают от организации, поняты и доведены до сведения
 - **GV. OC-05:** Результаты, возможности и услуги, от которых зависит организация, поняты и доведены до сведения
- **Стратегия управления рисками (GV.RM):** Приоритеты организации, ограничения, заявления о толерантности к риску и риск-аппетит, а также предположения устанавливаются, доводятся до сведения и используются для поддержки решений по операционным рискам
 - **GV. RM-01:** Цели управления рисками устанавливаются и согласовываются с заинтересованными сторонами организации
 - **GV. RM-02:** Утверждения о склонности к риску и толерантности к риску составляются, доводятся до сведения и поддерживаются

NIST Cybersecurity Framework 2.0

- **GV. RM-03:** Деятельность по управлению рисками кибербезопасности и ее результаты включены в процессы управления рисками предприятия
 - **GV. RM-04:** Определение и доведение до сведения общественности стратегического направления, описывающего соответствующие варианты реагирования на риски
 - **GV. RM-05:** Установлены линии связи в организации для устранения рисков кибербезопасности, включая риски со стороны поставщиков и третьих сторон
 - **GV. RM-06:** Разработан и распространен стандартизированный метод расчета, документирования, категоризации и приоритизации рисков кибербезопасности
 - **GV. RM-07:** Стратегические возможности (т.е. положительные риски) характеризуются и включаются в обсуждение рисков кибербезопасности организации
-
- **Роли, обязанности и полномочия (GV. RR):** Роли, обязанности и полномочия в области кибербезопасности для обеспечения подотчетности, оценки эффективности и постоянного совершенствования определены и доведены до сведения
 - **GV. PP-01:** Организационное руководство несет ответственность и подотчетно за риски кибербезопасности и способствует формированию культуры, которая осознает риски, этична и постоянно совершенствуется
 - **GV. PP-02:** Роли, обязанности и полномочия, связанные с управлением рисками кибербезопасности, устанавливаются, доводятся до сведения, понимаются и применяются
 - **GV. PP-03:** Выделяются достаточные ресурсы, соизмеримые со стратегией, ролями, обязанностями и политикой в области кибербезопасности
 - **GV. PP-04:** Кибербезопасность включена в практику управления человеческими ресурсами
-
- **Политика (GV. PO):** Организационная политика кибербезопасности устанавливается, доводится до сведения и применяется
 - **GV. PP-01:** Политика управления рисками кибербезопасности устанавливается на основе организационного контекста, стратегии кибербезопасности и приоритетов, а также доводится до сведения и применяется
 - **GV. PO-02:** Политика управления рисками кибербезопасности пересматривается, обновляется, доводится до сведения и применяется с учетом изменений в требованиях, угрозах, технологиях и миссии организации
-
- **Надзор (GV. OV):** Результаты деятельности по управлению рисками кибербезопасности в масштабах всей организации используются для информирования, улучшения и корректировки стратегии управления рисками
 - **GV. OV-01:** Результаты стратегии управления рисками кибербезопасности пересматриваются для информирования и корректировки стратегии и направления
 - **GV. OV-02:** Стратегия управления рисками кибербезопасности пересматривается и корректируется для обеспечения охвата организационных требований и рисков
 - **GV. OV-03:** Эффективность управления рисками кибербезопасности организации оценивается и анализируется на предмет необходимых корректировок
-



NIST Cybersecurity Framework 2.0

- **Управление рисками кибербезопасности в цепочке поставок в области (GV. SC):** Процессы управления рисками в цепочке поставок в киберпространстве идентифицируются, устанавливаются, управляются, контролируются и совершенствуются заинтересованными сторонами организации
 - **GV. SC-01:** Программа, стратегия, цели, политики и процессы управления рисками в цепочке поставок в сфере кибербезопасности разработаны и согласованы заинтересованными сторонами организации
 - **GV. SC-02:** Роли и обязанности поставщиков, клиентов и партнеров в области кибербезопасности устанавливаются, доводятся до сведения и координируются внутри компании и за ее пределами
 - **GV. SC-03:** Управление рисками в цепочке поставок кибербезопасности интегрировано в процессы кибербезопасности и управления рисками предприятия, оценки рисков и совершенствования
 - **GV. SC-04:** Поставщики известны и расставлены по приоритетам в зависимости от критичности
 - **GV. SC-05:** Требования по устранению рисков кибербезопасности в цепочках поставок устанавливаются, приоритизируются и интегрируются в контракты и другие виды соглашений с поставщиками и другими соответствующими третьими сторонами
 - **GV. SC-06:** Планирование и комплексная проверка проводятся для снижения рисков до вступления в официальные отношения с поставщиком или третьей стороной
 - **GV. SC-07:** Риски, связанные с поставщиком, его продуктами и услугами, а также другими третьими сторонами, понимаются, регистрируются, приоритизируются, оцениваются, реагируют и контролируются в течение всего периода отношений
 - **GV. SC-08:** Соответствующие поставщики и другие третьи стороны привлекаются к планированию инцидентов, реагированию на них и ликвидации последствий
 - **GV. SC-09:** Методы обеспечения безопасности цепочки поставок интегрированы в программы кибербезопасности и управления рисками предприятия, и их эффективность контролируется на протяжении всего жизненного цикла технологического продукта и услуги
 - **GV. ПК-10:** Планы управления рисками в цепочке поставок в области кибербезопасности включают положения о действиях, которые происходят после заключения соглашения о партнерстве или оказании услуг

IDENTIFY (ID): понимание текущих рисков кибербезопасности организации

- **Управление активами (ID.AM):** Активы (например, данные, оборудование, программное обеспечение, системы, объекты, услуги, люди), которые позволяют организации достигать бизнес-целей, идентифицируются и управляются в соответствии с их относительной важностью для целей организации и стратегии организации в отношении рисков
 - **ID.AM-01:** Инвентаризация оборудования, управляемого организацией, ведется



NIST Cybersecurity Framework 2.0

- **ID.AM-02:** Ведется инвентаризация программного обеспечения, услуг и систем, управляемых организацией
 - **ID.AM-03:** Поддерживаются представления об авторизованных сетевых коммуникациях организации, а также внутренних и внешних сетевых потоках данных
 - **ID.AM-04:** Инвентаризация услуг, предоставленных поставщиками, ведется
 - **ID.AM-05:** Активы приоритизированы на основе классификации, критичности, ресурсов и влияния на миссию
 - **ID.AM-07:** Инвентаризация данных и соответствующие метаданные для определенных типов данных ведутся
 - **ID.AM-08:** Системы, оборудование, программное обеспечение, услуги и данные управляются на протяжении всего их жизненного цикла
-
- **Оценка рисков (ID.RA):** Риск кибербезопасности для организации, активов и отдельных лиц понимается организацией
 - **ID.RA-01:** Уязвимости в активах выявляются, проверяются и регистрируются.
 - **ID.RA-02:** Информация о киберугрозах поступает из форумов и источников по обмену информацией
 - **ID.RA-03:** Идентифицированы и зарегистрированы внутренние и внешние угрозы для организации
 - **ID.RA-04:** Идентифицированы и зарегистрированы потенциальные последствия и вероятности угроз, использующих уязвимости.
 - **ID.RA-05:** Угрозы, уязвимости, вероятности и последствия используются для понимания присущих рисков и определения приоритетов реагирования на риски
 - **ID.RA-06:** Реакции на риски выбираются, приоритизируются, планируются, отслеживаются и доводятся до сведения
 - **ID.RA-07:** Изменения и исключения управляются, оцениваются на предмет влияния на риск, записываются и отслеживаются
 - **ID.RA-08:** Установлены процессы получения, анализа и реагирования на раскрытие уязвимостей
 - **ID.RA-09:** Подлинность и целостность аппаратного и программного обеспечения оцениваются перед приобретением и использованием
 - **ID.RA-10:** Критически важные поставщики оцениваются перед приобретением
-
- **Совершенствование (ID.IM):** Выявлены усовершенствования процессов, процедур и деятельности по управлению рисками кибербезопасности организации по всем функциям CSF
 - **ID.IM-01:** Усовершенствования выявлены на основе оценок
 - **ID.IM-02:** Усовершенствования выявлены на основе тестов и учений по обеспечению безопасности, в том числе выполненных в координации с поставщиками и соответствующими третьими сторонами
 - **ID.IM-03:** Выявлены улучшения в результате выполнения операционных процессов, процедур и действий



NIST Cybersecurity Framework 2.0

- **ID.IM-04:** Планы реагирования на инциденты и другие планы кибербезопасности, влияющие на операции, разрабатываются, передаются, поддерживаются и совершенствуются

PROTECT (PR): Используются меры безопасности для управления рисками кибербезопасности организации

- **Управление идентификацией, аутентификация и контроль доступа (PR. AA):** Доступ к физическим и логическим активам ограничен авторизованными пользователями, службами и оборудованием и управляется соразмерно оцененному риску несанкционированного доступа
 - **PR AA-01:** Идентификаторы и учетные данные для авторизованных пользователей, служб и оборудования управляются организацией
 - **PR. AA-02:** Идентификаторы проверяются и привязываются к учетным данным в зависимости от контекста взаимодействия
 - **PR. AA-03:** Пользователи, услуги и оборудование аутентифицируются
 - **PR. AA-04:** Утверждения идентичности (Identity assertions) защищены, переданы и проверены
 - **PR. AA-05:** Разрешения на доступ, права и полномочия определяются в политике, управляются, применяются и пересматриваются, а также включают в себя принципы наименьших привилегий и разделения обязанностей
 - **PR. AA-06:** Физический доступ к активам управляется, контролируется и обеспечивается соразмерно риску
- **Повышение осведомленности и обучение (PR. AT):** Персонал организации получает знания и обучение в области кибербезопасности, чтобы они могли выполнять свои задачи, связанные с кибербезопасностью
 - **PR. AT-01:** Персонал должен быть осведомлен и обучен, чтобы он обладал знаниями и навыками для выполнения общих задач с учетом рисков кибербезопасности
 - **PR. AT-02:** Лица, занимающие специализированные должности, проходят обучение и подготовку, чтобы они обладали знаниями и навыками для выполнения соответствующих задач с учетом рисков кибербезопасности
- **Безопасность данных (PR.DS):** Управление данными осуществляется в соответствии со стратегией организации по управлению рисками для защиты конфиденциальности, целостности и доступности информации
 - **PR. DS-01:** Конфиденциальность, целостность и доступность данных в состоянии покоя защищены
 - **PR. DS-02:** Конфиденциальность, целостность и доступность передаваемых данных защищены



NIST Cybersecurity Framework 2.0

- **PR. DS-10:** Конфиденциальность, целостность и доступность данных при обработке защищены
 - **PR. DS-11:** Резервные копии данных создаются, защищаются, обслуживаются и тестируются
-
- **Безопасность платформы (PR.PS):** Аппаратное обеспечение, программное обеспечение (например, встроенное ПО, операционные системы, приложения) и услуги физических и виртуальных платформ управляются в соответствии со стратегией организации в отношении рисков для защиты их конфиденциальности, целостности и доступности
 - **PR. PS-01:** Установлены и применяются методы управления конфигурацией
 - **PR. PS-02:** Программное обеспечение поддерживается, заменяется и удаляется соразмерно риску
 - **PR. PS-03:** Аппаратное обеспечение обслуживается, заменяется и удаляется соразмерно риску
 - **PR. PS-04:** Генерируются записи журнала аудита, которые становятся доступными для непрерывного мониторинга
 - **PR. PS-05:** Установка и выполнение несанкционированного программного обеспечения предотвращены
 - **PR. PS-06:** Безопасные методы разработки программного обеспечения интегрированы, и их производительность контролируется на протяжении всего жизненного цикла разработки программного обеспечения
-
- **Устойчивость технологической инфраструктуры (PR. IR):** Архитектуры безопасности управляются в соответствии со стратегией управления рисками организации для защиты конфиденциальности, целостности и доступности активов, а также организационной устойчивости
 - **PR. IR-01:** Сети и среды защищены от несанкционированного логического доступа и использования
 - **PR. IR-02:** Технологические активы организации защищены от угроз окружающей среды
 - **PR. IR-03:** Внедрены механизмы для достижения требований к устойчивости в нормальных и неблагоприятных ситуациях
 - **PR. IR-04:** Поддерживается достаточный ресурсный потенциал для обеспечения доступности
-

DETECT (DE): Поиск и анализ возможных атак и компрометации систем кибербезопасности

- **Непрерывный мониторинг (DE. CM):** Активы отслеживаются на предмет аномалий, индикаторов компрометации и других потенциально неблагоприятных событий
 - **DE. CM-01:** Осуществляется мониторинг сетей и сетевых служб для выявления потенциально нежелательных явлений
 - **DE. CM-02:** Физическая среда контролируется с целью выявления потенциально нежелательных явлений



NIST Cybersecurity Framework 2.0

- **DE. CM-03:** Осуществляется мониторинг активности персонала и использования технологий для выявления потенциально неблагоприятных событий
 - **DE. CM-06:** Осуществляется мониторинг деятельности и услуг внешних поставщиков услуг для выявления потенциально неблагоприятных событий
 - **DE. CM-09:** Компьютерное оборудование и программное обеспечение, среды выполнения и их данные отслеживаются для выявления потенциально неблагоприятных событий
-
- **Анализ нежелательных событий (DE. AE):** Аномалии, индикаторы компрометации и другие потенциально неблагоприятные события анализируются для характеристики событий и выявления инцидентов кибербезопасности
 - **DE. AE-02:** Потенциально неблагоприятные события анализируются для лучшего понимания связанных с ними действий
 - **DE. AE-03:** Информация коррелируется из нескольких источников
 - **DE. AE-04:** Предполагаемое влияние и масштаб нежелательных явлений понимаются
 - **DE. AE-06:** Информация о нежелательных явлениях предоставляется уполномоченному персоналу и инструментам
 - **DE. AE-07:** Разведка киберугроз и другая контекстуальная информация интегрированы в анализ
 - **DE. AE-08:** Инциденты объявляются, когда неблагоприятные события соответствуют определенным критериям инцидента
-

RESPONSE (RS): Предпринимаются действия в отношении обнаруженного инцидента кибербезопасности

- **Управление инцидентами (RS. MA):** Реагирование на обнаруженные инциденты кибербезопасности управляется
 - **RS. MA-01:** План реагирования на инцидент выполняется в координации с соответствующими третьими сторонами после объявления инцидента
 - **RS. MA-02:** Отчеты об инцидентах сортируются и проверяются
 - **RS. MA-03:** Инциденты классифицируются и приоритизируются
 - **RS. MA-04:** Инциденты эскалируются или повышаются по мере необходимости
 - **RS. MA-05:** Применяются критерии для начала восстановления после инцидента
 - **Анализ инцидентов (RS. AH):** Расследования проводятся для обеспечения эффективного реагирования и поддержки судебной экспертизы и деятельности по восстановлению
 - **RS. AH-03:** Анализ проводится для установления того, что произошло во время инцидента и первопричины инцидента
-



NIST Cybersecurity Framework 2.0

- **RS. AH-06:** Действия, совершенные в ходе расследования, записываются, а их целостность и происхождение сохраняются
 - **RS. AH-07:** Данные об инцидентах и метаданные собираются, а их целостность и происхождение сохраняются
 - **RS. AH-08:** Масштаб инцидента оценивается и проверяется
-
- **Отчетность и коммуникация по реагированию на инциденты (RS.CO):** Действия по реагированию координируются с внутренними и внешними заинтересованными сторонами в соответствии с требованиями законов, нормативных актов или политик
 - **RS.CO-02:** Внутренние и внешние заинтересованные стороны уведомляются об инцидентах
 - **RS. CO-03:** Осуществляется обмен информацией с назначенными внутренними и внешними заинтересованными сторонами
-
- **Снижение последствий инцидентов (RS.MI):** Действия выполняются для предотвращения распространения события и смягчения его последствий
 - **RS.MI-01:** Инциденты локализованы
 - **RS.MI-02:** Инциденты искореняются
-

RECOVER (RC): Активы и операции, затронутые инцидентом кибербезопасности, восстанавливаются

- **Выполнение плана восстановления после инцидентов (RC.RP):** Мероприятия по восстановлению выполняются для обеспечения операционной доступности систем и сервисов, пострадавших от инцидентов кибербезопасности
 - **RC. RP-01:** Часть плана реагирования на инциденты, связанная с восстановлением, выполняется после того, как процесс реагирования на инцидент был инициирован
 - **RC.RP-02:** Действия по восстановлению выбираются, определяются, приоритизируются и выполняются
 - **RC.RP-03:** Целостность резервных копий и других ресурсов восстановления проверяется перед использованием их для восстановления
 - **RC.RP-04:** Критически важные функции миссии и управление рисками кибербезопасности учитываются для установления оперативных норм после инцидента
 - **RC.RP-05:** Проверяется целостность восстановленных активов, восстанавливаются системы и сервисы, а также подтверждается нормальное рабочее состояние
 - **RC.RP-06:** Объявлено об окончании восстановления после инцидента на основе критериев, и документация по инциденту завершена.
-
- **Связь по восстановлению после инцидентов (RC.CO):** Восстановительные работы координируются с внутренними и внешними сторонами
-



NIST Cybersecurity Framework 2.0

- **RC.CO-03:** Информация о мероприятиях по восстановлению и прогрессе в восстановлении эксплуатационных возможностей доводится до сведения назначенных внутренних и внешних заинтересованных сторон
 - **RC.CO-04:** Общедоступные новости о восстановлении после инцидентов распространяются с использованием утвержденных методов и обмена сообщениями
-



Приложение Б. Уровни CSF

В таблице 2 приведена условная иллюстрация уровней CSF, рассмотренных в разделе 3. Уровни характеризуют строгость применяемых в организации методов управления рисками кибербезопасности (GOVERN) и методов управления рисками кибербезопасности (IDENTIFY, PROTECT, DETECT, RESPONSE и RECOVER).

Таблица 2. Условная иллюстрация уровней CSF

Уровень	Управление рисками кибербезопасности	Управление рисками кибербезопасности
Тип 1: Частичный	Управление применением стратегии управления рисками кибербезопасности организации осуществляется на разовой основе. Расстановка приоритетов носит ситуативный характер и формально не основана на целях или угрозах	На организационном уровне существует ограниченная осведомленность о рисках кибербезопасности. Организация внедряет управление рисками кибербезопасности на регулярной основе, в каждом конкретном случае. В организации могут отсутствовать процессы, которые позволяют обмениваться информацией о кибербезопасности внутри организации. Организация, как правило, не осведомлена о рисках кибербезопасности, связанных с ее поставщиками, а также с продуктами и услугами, которые она приобретает и использует.
Уровень 2: Риск Информированный	Методы управления рисками подтверждаются руководством, но могут быть не установлены в качестве общеорганизационной политики. Расстановка приоритетов в области кибербезопасности и потребностей в защите напрямую зависит от целей рисков организации, угроз или требований бизнеса/миссии.	На организационном уровне существует осведомленность о рисках кибербезопасности, но общеорганизационный подход к управлению рисками кибербезопасности не выработан. Учет кибербезопасности в целях и программах организации может иметь место на некоторых, но не на всех уровнях организации. Оценка киберрисков для организационных и внешних активов происходит, но обычно не повторяется на постоянной основе. Обмен информацией о кибербезопасности внутри организации осуществляется на неформальной основе. Организация осведомлена о рисках кибербезопасности, связанных с ее поставщиками, а также с продуктами и услугами, которые она приобретает и использует, но она не действует последовательно или формально в ответ на эти риски.



NIST Cybersecurity Framework 2.0

Уровень	Управление рисками кибербезопасности	Управление рисками кибербезопасности
Тир 3: Повторяемый	Методы управления рисками в организации официально утверждены и выражены в виде политики. Политики, процессы и процедуры, основанные на учете рисков, определяются, внедряются в соответствии с задуманным планом и пересматриваются. Организационные практики кибербезопасности регулярно обновляются на основе применения процессов управления рисками к изменениям в требованиях бизнеса/миссии, угрозах и технологическом ландшафте.	Существует общеорганизационный подход к управлению рисками кибербезопасности. Информация о кибербезопасности регулярно распространяется по всей организации. Существуют согласованные методы эффективного реагирования на изменения рисков. Персонал обладает знаниями и навыками для выполнения назначенных ему ролей и обязанностей. Организация последовательно и точно отслеживает риски кибербезопасности активов. Старшие руководители по кибербезопасности и руководители, не связанные с кибербезопасностью, регулярно общаются о рисках кибербезопасности. Руководители следят за тем, чтобы кибербезопасность учитывалась во всех направлениях деятельности организации. Стратегия организации управления рисками основана на рисках кибербезопасности, связанных с ее поставщиками, а также с продуктами и услугами, которые она приобретает и использует. Персонал формально реагирует на эти риски с помощью таких механизмов, как письменные соглашения о базовых требованиях, структуры управления (например, советы по рискам), а также реализация и мониторинг политики. Эти действия реализуются последовательно и в соответствии с планом, а также постоянно контролируются и пересматриваются.
Тир 4: Адаптивный	Существует общеорганизационный подход к управлению рисками кибербезопасности, который использует политики, процессы и процедуры с учетом рисков для реагирования на потенциальные события кибербезопасности. Взаимосвязь между рисками кибербезопасности и целями организации четко понимается и учитывается при принятии решений. Руководители отслеживают риски кибербезопасности в том же контексте, что и финансовые и другие организационные риски. Бюджет организации основан на понимании текущей и прогнозируемой среды рисков и толерантности к рискам. Бизнес-	Организация адаптирует свои методы кибербезопасности на основе предыдущих и текущих действий в области кибербезопасности, включая извлеченные уроки и прогнозные показатели. Благодаря процессу непрерывного совершенствования, который включает в себя передовые технологии и практики кибербезопасности, организация активно адаптируется к меняющемуся технологическому ландшафту и своевременно и эффективно реагирует на развивающиеся, изощренные угрозы. Организация использует информацию в режиме реального времени или близком к реальному времени, чтобы понимать и последовательно реагировать на риски кибербезопасности, связанные с ее поставщиками, а также продуктами и услугами, которые она приобретает и использует.



NIST Cybersecurity Framework 2.0

Уровень	Управление рисками кибербезопасности	Управление рисками кибербезопасности
	единицы реализуют видение руководства и анализируют риски на системном уровне в контексте организационных допустимых рисков. Управление рисками кибербезопасности является частью организационной культуры. Она развивается из осознания предыдущей деятельности и постоянной осведомленности о деятельности в организационных системах и сетях. Организация может быстро и эффективно учитывать изменения в бизнес-целях/миссиях в подходе к рискам и их распространении.	Информация о кибербезопасности постоянно передается по всей организации и уполномоченным третьим сторонам



Приложение В. Глоссарий

Категория CSF (CSF Category)

Группа взаимосвязанных результатов кибербезопасности, которые в совокупности составляют функцию CSF.

Профиль сообщества CSF (CSF Community Profile)

Структура результатов CSF, который создается и публикуется с учетом общих интересов и целей ряда организаций. Профиль сообщества обычно разрабатывается для определенного сектора, подсектора, технологии, типа угрозы или другого варианта использования. Организация может использовать профиль сообщества в качестве основы для своего собственного целевого профиля.

Ядро CSF (CSF Core)

Таксономия высокоуровневых результатов кибербезопасности, которая может помочь любой организации управлять рисками кибербезопасности. Его компоненты представляют собой иерархию функций, категорий и подкатегорий, в которых подробно описывается каждый результат.

Текущий профиль CSF (CSF Current Profile)

Часть организационного профиля, которая определяет основные результаты, которые организация в настоящее время достигает (или пытается достичь), и характеризует, как или в какой степени достигается каждый результат.

Функция CSF (CSF Function)

Самый высокий уровень организации для достижения результатов в области кибербезопасности. Существует шесть функций CSF: GOVERN (Управлять), IDENTIFY (Идентифицировать), PROTECT (Защищать), DETECT (Обнаруживать), RESPOND (Реагировать), и RECOVER (Восстанавливать).

Пример реализации CSF (CSF Implementation Example)

Краткая, ориентированная на действие, концептуальная иллюстрация способа, который поможет достичь результата ядра CSF.

Информационная ссылка CSF (CSF Informative Reference)

Сопоставление, указывающее на взаимосвязь между результатом ядра CSF и существующим стандартом, руководством, регламентом или другим содержанием.

Организационный профиль CSF (CSF Organizational Profile)

Механизм для описания текущего и/или целевого состояния кибербезопасности организации с точки зрения результатов ядра CSF.

Руководства по быстрому запуску CSF (CSF Quick Start Guide)

Дополнительный ресурс, который дает краткие, действенные рекомендации по конкретным темам, связанным с CSF.

Подкатегория CSF (CSF Subcategory)

Группа более конкретных результатов технических и управленческих действий в области кибербезопасности, составляющих категорию CSF.

Целевой профиль CSF (CSF Target Profile)

Часть организационного профиля, в которой указываются желаемые основные результаты, выбранные организацией и приоритизированные для достижения целей управления рисками кибербезопасности.

Уровень CSF (CSF Tier)

Характеристика строгости методов руководства и правления рисками кибербезопасности в организации. Существует четыре уровня: частичный (уровень 1), информированный о рисках (уровень 2), повторяемый (уровень 3) и адаптивный (уровень 4).



NIST Cybersecurity Framework 2.0

Определенное коммерческое оборудование, средства, программное обеспечение или материалы, коммерческие или некоммерческие, указаны в настоящем документе для адекватного определения экспериментальной процедуры. Такая идентификация не подразумевает рекомендацию или одобрение какого-либо продукта или услуги со стороны NIST, а также не означает, что указанные продукты и услуги обязательно являются наилучшими доступными для этой цели.

Политика NIST в отношении технических серий

[Copyright, Use, and Licensing Statements](#) [NIST](#)

[Technical Series Publication Identifier Syntax](#)

Как цитировать эту публикацию технической серии NIST:

National Institute of Standards and Technology (2024) The NIST Cybersecurity Framework (CSF) 2.0. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Cybersecurity White Paper (CSWP) NIST CSWP 29. <https://doi.org/10.6028/NIST.CSWP.29>

Контактная информация

cyberframework@nist.gov

National Institute of Standards and Technology

Attn: Applied Cybersecurity Division, Information Technology Laboratory

100 Bureau Drive (Mail Stop 2000) Gaithersburg, MD 20899-2000